

REPORT S9/L3

MALWARE ANALYSIS REPORT

WannaCry / WannaCrypt0rRansomware

THREAT LEVEL: KNOWN BAD

SCORE: 10 / 10

1. Panoramica del Campione

Sample ID	260603-qll18agy6m
Nome file	WannaCry.exe (anche WannaCrypt0r.exe)
SHA-256	be22645c61949ad6a077373a7d6cd85e3fae44315632f161adc4c99d5a8e6844
Dimensione	224 KB
Tipo	PE32 — Eseguibile Windows (non firmato digitalmente)
Famiglia	WannaCry
Classificazione	Known Bad — Ransomware / Worm
Score	10 / 10
Data submit	2026-06-03 13:21 UTC
Piattaforma sandbox	win11-20260513-it (Windows 11, locale italiano)
Tag tria.ge	wannacry · ransomware · worm · adware · spyware · stealer · defense_evasion · discovery · execution

Il file **WannaCry.exe** è un campione del famigerato ransomware-worm WannaCry (noto anche come WannaCrypt0r), comparso per la prima volta nel maggio 2017. Si tratta di uno dei malware più distruttivi della storia informatica recente: in poche ore infettò oltre 200.000 sistemi in 150 paesi, colpendo ospedali, aziende di telecomunicazioni e infrastrutture critiche. L'analisi seguente è condotta sul report comportamentale prodotto dalla sandbox tria.ge.

2. Scopo del Malware

WannaCry persegue due obiettivi principali in parallelo:

2.1 Cifratura dei file (Ransomware)

Una volta eseguito, il malware ricerca e cifra i file dell'utente aggiungendo l'estensione **.WCRY**. Alla vittima viene mostrata una schermata di riscatto (tramite !WannaDecryptor!.exe) che richiede il pagamento in Bitcoin per ottenere la chiave di decifratura. Lo sfondo del desktop viene sostituito con un'immagine di avviso (!WannaCrytor!.bmp). Una nota testuale (!Please Read Me!.txt) viene depositata sul sistema.

2.2 Propagazione autonoma (Worm)

Il malware si propaga lateralmente nella rete sfruttando la vulnerabilità **EternalBlue (MS17-010)** sul protocollo SMB (porta 445). Questa tecnica gli consente di infettare automaticamente altri host vulnerabili senza interazione dell'utente, comportandosi come un worm di rete.

3. Analisi Comportamentale — Fasi di Esecuzione

Il report tria.ge (behavioral1) documenta le seguenti fasi di esecuzione osservate nella sandbox:

Fase 1 — Avvio e Process Injection

Il malware viene lanciato da `C:\Users\Admin\AppData\Local\Temp\WannaCry.exe`. Immediatamente

utilizza **WriteProcessMemory** per iniettare codice in processi di sistema legittimi quali `cmd.exe`, `taskkill.exe` e il processo `!WannaDecryptor!.exe` che rilascia autonomamente. Questa tecnica di process injection (MITRE T1055) consente di eseguire codice malevolo nel contesto di processi trusted, eludendo alcuni controlli di sicurezza.

Fase 2 — Persistenza nel sistema

Viene aggiunta una chiave di autorun nel registro di sistema per garantire la sopravvivenza ai riavvii:

```
HKLM\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Run\ Microsoft Update Task Scheduler = "C:\...\WannaCry.exe /r"
```

Viene inoltre creato un file di avvio nella cartella Startup dell'utente (`AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\`), garantendo una doppia via di persistenza (MITRE T1547.001).

Fase 3 — Eliminazione dei backup (Shadow Copy)

■ Questa è la fase più critica: rende impossibile il ripristino del sistema senza il pagamento del riscatto.

Il malware esegue tramite `cmd.exe` una serie di comandi devastanti:

```
vssadmin delete shadows /all /quiet wmic shadowcopy delete bcdedit /set {default} bootstatuspolicy ignoreallfailures bcdedit /set {default} recoveryenabled no wadmin delete catalog -quiet
```

Questi comandi eliminano tutte le Shadow Copy (copie shadow del volume), disabilitano il ripristino automatico di Windows e cancellano il catalogo di Windows Backup, rendendo di fatto impossibile qualsiasi recupero dei dati tramite strumenti nativi del sistema operativo (MITRE T1490).

Fase 4 — Kill di processi critici

Prima di procedere alla cifratura, il malware termina i processi di database e server di posta per liberare i lock sui file e cifrarne il contenuto:

```
taskkill /f /im MExchange* taskkill /f /im Microsoft.Exchange.* taskkill /f /im sqlserver.exe  
taskkill /f /im sqlwriter.exe
```

Questo garantisce che i file dei database (SQL Server, Exchange) siano accessibili e quindi cifrabili, massimizzando il danno all'organizzazione vittima.

Fase 5 — Cifratura dei file

Il componente !WannaDecryptor!.exe viene rilasciato ed eseguito. Esso enumera i dispositivi di storage fisici e cifra i file dell'utente. La sandbox ha registrato la creazione del file TestRegister.mpeg.WCRY sul Desktop — prova diretta dell'avvenuta cifratura. Il registro di sistema viene modificato per associare l'estensione **.WCRY** al programma WannaDecryptor, in modo che i file cifrati vengano aperti automaticamente con il componente di riscatto.

Fase 6 — Connessioni di rete e comunicazione C2

Il malware tenta ripetutamente connessioni TCP alle porte **9050** e **9150** su localhost — le porte standard di **Tor** — per anonimizzare le comunicazioni con il server di Command & Control. Viene inoltre registrata una connessione verso l'IP esterno **92.123.128.189:443** (geolocalizzato in UK), probabile endpoint C2 o server per la consegna della chiave di cifratura.

Fase 7 — Rilevamento lingua di sistema

Il malware interroga ripetutamente la chiave di registro HKLM\SYSTEM\ControlSet001\Control\NLS\Language da molteplici processi, incluso il processo principale. Questa tecnica (MITRE T1614.001) viene utilizzata per verificare la lingua configurata nel sistema:

alcune varianti di WannaCry evitano di cifrare sistemi con determinate impostazioni locali.

4. Mappatura MITRE ATT&CK; — Enterprise Matrix V16

Le seguenti tecniche sono state rilevate dalla sandbox tria.ge durante l'analisi comportamentale:

Tattica	Tecnica	ID
Execution	Windows Management Instrumentation	T1047
Persistence	Boot/Logon Autostart — Registry Run Keys	T1547.001
Privilege Escalation	Boot/Logon Autostart — Registry Run Keys	T1547.001
Defense Evasion	Indicator Removal — File Deletion	T1070.004
Defense Evasion	Modify Registry	T1112
Credential Access	Credentials from Web Browsers	T1555.003
Credential Access	Credentials In Files	T1552.001
Discovery	Query Registry	T1012
Discovery	System Information Discovery	T1082
Discovery	System Language Discovery	T1614.001
Collection	Data from Local System	T1005
Impact	Defacement — Internal Defacement	T1491
Impact	Inhibit System Recovery	T1490

La tecnica più impattante è **T1490 — Inhibit System Recovery**: la cancellazione delle Shadow Copy è ciò che rende il ransomware particolarmente devastante, poiché impedisce il ripristino del sistema senza il pagamento del riscatto.

5. File Rilasciati (Dropped Files)

File rilasciato	Ruolo
!WannaDecryptor!.exe	Componente principale: cifratura file e GUI del riscatto
!WannaDecryptor!.exe.lnk	Collegamento per avvio automatico del decryptor
!Please Read Me!.txt	Nota di riscatto in formato testo
307781780493422.bat	Script batch per comandi di sistema (shadow copy, bcdedit)
c.vbs	Script VBScript ausiliario per esecuzione di comandi
u.wry / t.wry / r.wry	Risorse interne del ransomware (configurazione/chiavi)
c.wry / m.wry	Ulteriori risorse cifrate interne
00000000.res	File di risorse utilizzato dal componente decryptor
TestRegister.mpeg.WCRY	File cifrato (prova di cifratura sul Desktop della sandbox)

6. Attività di Rete

Destinazione	Porta	Protocollo	Note
127.0.0.1	9050	TCP	Porta Tor — proxy anonimizzazione C2
127.0.0.1	9150	TCP	Porta Tor Browser — proxy anonimizzazione C2
92.123.128.189	443	TCP	IP esterno (UK) — probabile server C2 / key server

Le connessioni ripetute alle porte 9050 e 9150 indicano che il malware tenta di instradare le comunicazioni attraverso la rete **Tor**, rendendo estremamente difficile l'identificazione del server C2. La connessione verso **92.123.128.189** potrebbe corrispondere al server da cui il malware scarica la chiave di cifratura pubblica o invia informazioni sulla vittima.

Nota: il famoso **killswitch** di WannaCry (un dominio specifico che, se raggiungibile, blocca l'esecuzione) non risulta visibile in questo report — la sandbox probabilmente blocca le richieste DNS esterne o il dominio non è presente in questa variante del campione.

7. Analisi Statica

Tipo file	PE32 — Portable Executable (32-bit)
Firma digitale	ASSENTE — Unsigned PE (primo indicatore di sospetto)
Dimensione	224 KB
Esecuzione	C:\Users\Admin\AppData\Local\Temp\WannaCry.exe
Tempo analisi kernel	149 secondi
Tempo analisi rete	150 secondi

L'assenza di firma digitale è un indicatore immediato di sospetto: nessun software legittimo viene distribuito senza firma nei moderni ambienti Windows. La dimensione contenuta (224 KB) è coerente con un dropper compresso che estrae i componenti a runtime.

8. Risposte ai Quesiti dell'Esercitazione

Q1 — Qual è lo scopo del malware?

WannaCry è un **ransomware-worm**. Il suo scopo è duplice: cifrare i file della vittima aggiungendo l'estensione **.WCRY** e richiedere un riscatto in Bitcoin, e propagarsi autonomamente in rete sfruttando la vulnerabilità **EternalBlue (MS17-010)** sul protocollo SMB, infettando altri host senza interazione dell'utente.

Q2 — Ha meccanismi di persistenza?

Sì, il malware implementa una doppia persistenza:

1) Aggiunta di una chiave **Run** nel registro di sistema `HKLM\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Run` con il valore `Microsoft Update Task Scheduler` — nome scelto deliberatamente per mimetizzarsi tra i processi di sistema legittimi.

2) Creazione di un file temporaneo (`~SD2B50.tmp`) nella cartella **Startup** di Windows, che garantisce l'esecuzione automatica a ogni avvio di sessione utente.

Q3 — Elimina i backup di sistema?

Sì, questa è una delle azioni più critiche del malware (**MITRE T1490**). Tramite un file batch (`307781780493422.bat`) esegue:

```
vssadmin delete shadows /all /quiet wmic shadowcopy delete bcdedit /set {default}
bootstatuspolicy ignoreallfailures bcdedit /set {default} recoveryenabled no wbadm delete
catalog -quiet
```

Queste operazioni eliminano tutte le **Shadow Copy (VSS)**, disabilitano il ripristino automatico al boot e cancellano il catalogo di Windows Backup, rendendo il recupero dei dati impossibile senza la chiave di decifratura.

Q4 — Tenta connessioni di rete? A quali indirizzi?

Sì. Il malware tenta connessioni TCP verso:

- **127.0.0.1:9050** e **127.0.0.1:9150** — porte standard del client **Tor**, usate per anonimizzare le comunicazioni con il server C2.
- **92.123.128.189:443** (UK) — probabile server C2 o server per la distribuzione/ricezione delle chiavi crittografiche.

L'uso di Tor è una tecnica sofisticata che rende estremamente difficile il tracciamento degli operatori del malware e l'identificazione dell'infrastruttura C2.

Q5 — Cosa cifra e come lo segnala alla vittima?

Il malware cifra i file dell'utente aggiungendo l'estensione **.WCRY**. La prova diretta nella sandbox è il file `TestRegister.mpeg.WCRY` creato sul Desktop. Per segnalare l'infezione alla vittima:

- Modifica lo **sfondo del desktop** con l'immagine `!WannaCryptor!.bmp` (**MITRE T1491**).
 - Crea il file `!Please Read Me!.txt` con le istruzioni per il pagamento del riscatto.
 - Apre automaticamente `!WannaDecryptor!.exe` che mostra la GUI con il conto alla rovescia e l'indirizzo Bitcoin.
 - Registra l'estensione **.WCRY** nel sistema (`OpenWith.exe`) associandola ad Adobe Reader, così che il tentativo di aprire un file cifrato mostri un messaggio di errore ulteriormente disorientante.
-

Q6 — Quali tecniche di evasione utilizza?

Il malware implementa diverse tecniche di defense evasion:

- **Process Injection (WriteProcessMemory)**: inietta codice in processi legittimi (cmd.exe, taskkill.exe) per eseguire operazioni nel loro contesto trusted.
- **Privilege Escalation (AdjustPrivilegeToken)**: richiede SeDebugPrivilege tramite taskkill.exe e numerosi altri privilegi tramite WMIC.exe per operare con permessi elevati.
- **SetWindowsHookEx**: installa hook di sistema (possibile keylogging o intercettazione di input) tramite !WannaDecryptor!.exe.
- **Nomi ingannevoli**: la chiave di persistenza si chiama Microsoft Update Task Scheduler per sembrare un aggiornamento legittimo.
- **Comunicazione via Tor**: anonimizza il traffico C2.

Q7 — Raccoglie credenziali o dati sensibili?

Sì. Il report tria.ge classifica il malware anche come **spyware** e **stealer**. Vengono rilevate due tecniche di Credential Access:

- **T1555.003 — Credentials from Web Browsers**: il malware legge i profili e i dati salvati nei browser web.
- **T1552.001 — Credentials In Files**: ricerca credenziali memorizzate in file nel filesystem.

Questo comportamento, non tipico di un ransomware puro, suggerisce che questa variante potrebbe essere arricchita di funzionalità di furto dati, o che la sandbox ha rilevato comportamenti collaterali del componente !WannaDecryptor!.exe.

Q8 — Qual è il suo score di pericolosità e perché?

Il campione ottiene il punteggio massimo: **10/10 — Known Bad**. Questo punteggio è giustificato dalla combinazione di fattori ad alto impatto:

- Cifratura irreversibile dei file senza backup (shadow copy eliminate).
- Capacità di propagazione autonoma come worm.
- Raccolta di credenziali e dati sensibili.
- Meccanismi di persistenza multipli.
- Comunicazione C2 anonimizzata via Tor.
- Kill di processi critici (database, Exchange Server).
- Famiglia malware già nota e classificata come estremamente pericolosa.

9. Indicatori di Compromissione (IOC)

SHA-256 (campione)	be22645c61949ad6a077373a7d6cd85e3fae44315632f161adc4c99d5a8e6844
SHA-256 (!WannaDecryptor!.exe)	— (rilevato come processo figlio)
IP esterno	92.123.128.189 (porta 443, TCP)
Porte locali Tor	9050, 9150 (TCP su 127.0.0.1)
Chiave registro	HKLM\...\Run\Microsoft Update Task Scheduler

Estensione file	.WCRY (file cifrati)
File nota riscatto	!Please Read Me!.txt
Sfondo desktop	!WannaCryptor!.bmp
Comando bat	vssadmin delete shadows /all /quiet

10. Conclusioni

L'analisi sandbox condotta su tria.ge conferma che il campione **WannaCry.exe** è un esemplare altamente pericoloso del ransomware-worm WannaCry, uno dei malware più impattanti della storia della cybersecurity. Il campione esibisce l'intera catena di attacco caratteristica di questa famiglia: dalla persistenza nel registro, alla distruzione sistematica dei backup, fino alla cifratura dei file e alla richiesta di riscatto.

Particolarmente degno di nota è il comportamento di **credential stealing** (tecniche T1555.003 e T1552.001), che arricchisce il profilo del campione oltre la semplice funzione ransomware, rendendolo una minaccia multifase. L'uso di **Tor** per le comunicazioni C2 dimostra un livello di sofisticazione operativa elevato.

Dal punto di vista difensivo, la mitigazione più efficace contro questa famiglia è il patching tempestivo della vulnerabilità **MS17-010** (EternalBlue) e la gestione di backup offline non raggiungibili dal malware. La presenza di Shadow Copy non è sufficiente: come dimostrato dall'analisi, WannaCry le elimina sistematicamente come prima operazione.
